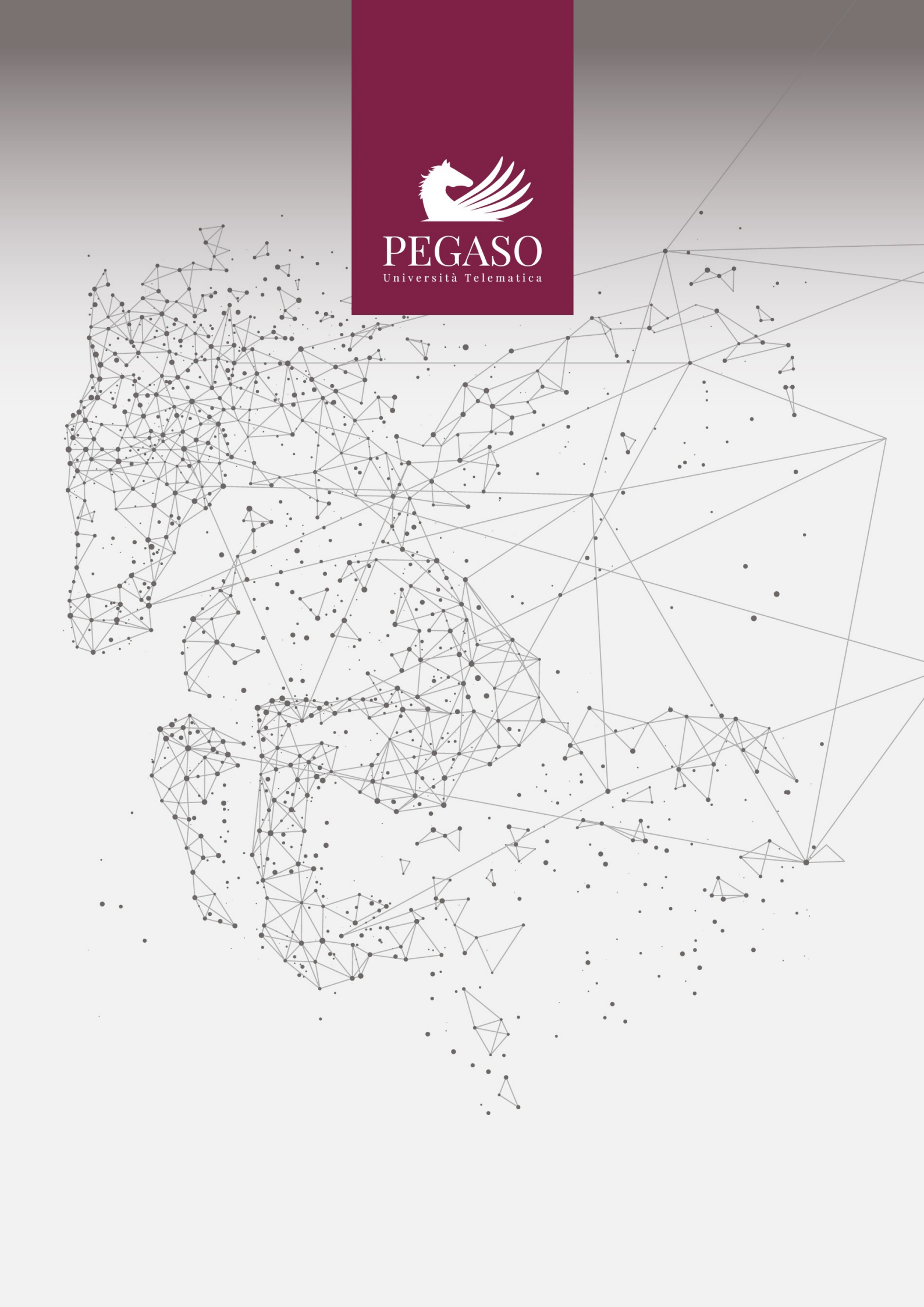

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 INTRUSIONI 3

2 SOFTWARE DOLOSO 7

3 I VIRUS 9

BIBLIOGRAFIA 11

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Intrusioni

Il principale problema dei sistemi connessi in rete riguarda le **intrusioni** dovute a utenti o software più o meno ostili. Gli utenti ostili possono effettuare violazioni come login non autorizzati o accesso a informazioni di livello superiore rispetto a quanto consentito, invece le violazioni di tipo software sono costituite dall'uso/distribuzione/iniezione di codice doloso di differente tipologia ed efficacia. Possono riguardare o meno la connessione di rete; per esempio nel caso di una violazione locale, l'attaccante cerca di guadagnare un accesso ad un terminale operando direttamente su di esso.

Gli utenti che effettuano violazioni (*hacker*) possono fondamentalmente essere catalogati in tre classi distinte:

- *Utente sotto mentite spoglie*: utente che elude i controlli di accesso e sfrutta l'account di un utente legittimo
- *Utente legittimo disonesto*: utente che sfrutta scorrettamente i propri privilegi per accedere a risorse a cui non potrebbe
- *Utente clandestino*: utente che acquisisce il controllo di un sistema come «supervisore».

Uno degli attacchi informatici più classici riguarda sicuramente l'acquisizione di informazioni sul **file delle password** che può permettere all'hacker di connettersi ad un sistema per iniziare la sua azione. Il file delle password è un file che associa l'utente autorizzato ad una determinata password. Per evitare o almeno limitare tale tipo di attacco, le password vengono cifrate opportunamente prima di essere memorizzate, per esempio tramite l'uso di hash crittografici; in fase di accesso dell'utente il sistema riesegue la stessa operazione di hash e confronta il risultato con quanto presente nel file delle password. Un altro semplice accorgimento consiste nel limitare per quanto possibile il numero di account che hanno accesso a tale file.

Le tecniche impiegate per la violazione delle password sono molteplici, tra gli approcci di base ci sono quelle cosiddette di *guess* ovvero che tentano di indovinare la password, come ad esempio:

- Tentare le password standard (account di base non modificati)

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Provare in maniera esaustiva quelli brevi (1-3 caratteri)
- Provare le password probabili o di qualche dizionario disponibile on-line
- Raccogliere informazioni sugli utenti (nome moglie, codice fiscale, data di nascita, targa auto, ecc.)

In figura qui sotto sono riportate le password usate più di frequente in ordine decrescente di frequenza.

Posizione	Password
1	123456
2	password
3	12345678
4	qwerty
5	12345
6	123456789
7	football
8	1234
9	1234567
10	baseball

Come si può osservare molte di queste sono molto semplici, facile da ricordare e soprattutto simili tra loro: ciò non garantisce ovviamente un ottimale livello di sicurezza.

Le tecniche di violazione basate sul *guess* sono comunque piuttosto primordiali e inoltre:

- richiedono vari tentativi automatici
- sono rilevabili perché richiedono tempo e generano anomalie nel sistema
- sono ostacolabili da semplici sistemi che bloccano le prove di accesso (disconnessione dopo alcuni tentativi, blocco temporale, ecc.)

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Altre tecniche di violazione più complesse prevedono l'utilizzo di software specifico o la realizzazione di programmi di hacking, ne sono un esempio:

- l'uso di *Cavalli di Troia* ovvero far eseguire un programma apparentemente innocuo ma contenente software doloso al sistema o ad un utente con privilegi da amministratore
- l'intercettazione della comunicazione fra due entità (utente remoto e sistema host): rientra nella problematica di violazione degli strumenti crittografici

Dall'altro lato, ovvero quello della difesa dagli attacchi e della realizzazione di contromisure, ciò che si fa è cercare di rilevare le possibili intrusioni o, ancor prima, i tentativi di intrusione. Questa azione può essere fondamentalmente fatta in due modi:

- attraverso *modelli statistici* costruiti sui comportamenti degli utenti legittimi su un determinato periodo temporale
  - modelli basati sull'uso di soglie
  - modelli basati sull'uso di profili
- attraverso la definizione di una serie di regole

La difficoltà principale di realizzare tali sistemi sta nell'ottenere un giusto trade-off (compromesso) fra la classificazione dell'utente legittimo e dell'hacker per evitare problematiche sia di «falsi allarmi» sia, dall'altro lato, di «mancata rilevazione».

È comunque importante dare la dovuta considerazione alla strategia di scelta delle password, che, anche in questo caso, è un compromesso fra:

- password brevi e/o facili da ricordare per l'utente ma con un livello basso di sicurezza
- password costituite da una serie di caratteri alfa-numerici, generati automaticamente, che garantiscono un elevato livello di sicurezza ma difficili da ricordare per l'utente

In molti casi quello che viene messo in pratica è un cosiddetto *controllo proattivo* in cui l'utente riceve delle indicazioni su come generare la password e poi il sistema ne verifica la

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

robustezza e conseguente accettabilità di ciò che l'utente ha inserito sulla base di criteri definiti.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Software doloso

Le minacce più sofisticate contro i computer e le reti di computer sono senza dubbio costituite dal software doloso (malevolo), *malware*. Qui di seguito viene presentata una definizione di malware.

Malware: un programma che è inserito in maniera nascosta all'interno di un altro o indipendente, creato con l'intento di distruggere dei dati, lanciare programmi dannosi o compromettere la segretezza, l'integrità o la disponibilità di dati e applicazioni dell'utente vittima dell'attacco.

Esistono sostanzialmente due categorie di malware:

- *richiede un programma ospite* (frammenti di codice in un programma applicativo, di sistema, ecc.)
- *opera in modo indipendente* (programmi completi eseguiti dal sistema operativo come worm e zombie).

I malware possono anche essere distinti diversamente:

- Software che *si replicano* ovvero quando attivati generano più copie di loro stessi (virus e worm)
- Software che *non si replicano* come i trojan (*cavalli di Troia*) e le e-mail spam.

Molti e differenti sono i nomi con cui vengono indicati i vari malware a seconda delle loro specifiche caratteristiche: virus, worm, bombe logiche, keylogger, syware, trojan e così via. Qui di seguito è riportata una tabella che contiene un elenco dei principali malware conosciuti evidenziandone sommariamente la tipologia di azione dannosa apportata.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Name	Description
Virus	Malware that, when executed, tries to replicate itself into other executable code; when it succeeds the code is said to be infected. When the infected code is executed, the virus also executes.
Worm	A computer program that can run independently and can propagate a complete working version of itself onto other hosts on a network.
Logic bomb	A program inserted into software by an intruder. A logic bomb lies dormant until a predefined condition is met; the program then triggers an unauthorized act.
Trojan horse	A computer program that appears to have a useful function, but also has a hidden and potentially malicious function that evades security mechanisms, sometimes by exploiting legitimate authorizations of a system entity that invokes the Trojan horse program.
Backdoor (trapdoor)	Any mechanisms that bypasses a normal security check; it may allow unauthorized access to functionality.
Mobile code	Software (e.g., script, macro, or other portable instruction) that can be shipped unchanged to a heterogeneous collection of platforms and execute with identical semantics.

Name	Description
Exploits	Code specific to a single vulnerability or set of vulnerabilities.
Downloaders	Program that installs other items on a machine that is under attack. Usually, a downloader is sent in an e-mail.
Auto-rooter	Malicious hacker tools used to break into new machines remotely.
Kit (virus generator)	Set of tools for generating new viruses automatically.
Spammer programs	Used to send large volumes of unwanted e-mail.
Flooders	Used to attack networked computer systems with a large volume of traffic to carry out a denial-of-service (DoS) attack.
Keyloggers	Captures keystrokes on a compromised system.
Rootkit	Set of hacker tools used after attacker has broken into a computer system and gained root-level access.
Zombie, bot	Program activated on an infected machine that is activated to launch attacks on other machines.
Spyware	Software that collects information from a computer and transmits it to another system.
Adware	Advertising that is integrated into software. It can result in pop-up ads or redirection of a browser to a commercial site.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 I virus

Un virus è un programma che può infettare altri programmi o ogni tipo di contenuto eseguibile effettuando su di loro delle modifiche. Il virus trasporta il codice necessario per eseguire copie di se stesso e contagiare un programma di un computer; quando il computer infettato entra in contatto con un software sano, il virus infetta questo nuovo programma e così via.

Lo scambio di memorie di massa e programmi fra utenti, sia fisicamente sia attraverso la rete, determina la propagazione del virus. Il virus viene eseguito segretamente con il programma che lo ospita e quando il virus è in esecuzione può svolgere qualsiasi funzione (e.g. cancellare dati).

Il ciclo di vita di un virus fondamentalmente si articola su **4 fasi**:

1. *Fase dormiente (*non sempre presente*)*: il virus è inattivo e sarà eventualmente attivato da un evento (e.g. superamento di un certo limite di capacità del disco)

2. *Fase di propagazione*: il virus inserisce una copia di se stesso in altri programmi o in certe aree del disco. La copia può anche essere leggermente diversa per ridurre la rilevazione da parte di un antivirus.

3. *Fase di attivazione*: il virus è attivato per svolgere la funzione per cui è stato concepito; tale fase può essere innescata da vari eventi

4. *Fase di esecuzione*: il virus svolge la sua funzione, come inviare un semplice messaggio a schermo o ancor peggio distruggere dei file.

Esistono varie modalità di classificazione dei virus: *classificazione in base al target*.

- *Virus per il settore di boot:* infettano il record di avvio principale del sistema e vengono diffusi quando il sistema viene avviato.

- *Virus per i file*: sono quelli più comuni, infettano i file eseguibili e si replicano quando il programma infetto è eseguito

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- *Virus per le macro*: infettano i file contenenti codici macro (programma eseguibile incluso in un documento, come nel caso di *Word*)

- *Virus multi-componente*: infettano i file in modi differenti, per eliminare questi tipi di virus bisogna considerare ogni tipo di infezione.

Un'altra modalità di classificazione dei virus riguarda la strategia usata per nascondersi.

- *Virus cifrati*: una parte del virus crea una chiave casuale con cui cifra la parte restante; la chiave viene incorporata nel virus che, quando viene attivato, utilizza tale chiave per decifrare la parte di virus criptata. Quando il virus si replica genera una chiave differente.

- *Virus invisibili*: progettati esplicitamente per non essere rivelati (e.g. uso di tecniche di compressione)

- *Virus polimorfici:* quando si replicano cambiano di forma pur mantenendo lo stesso comportamento

- *Virus metamorfici:* sono uguali a quelli polimorfici ma cambiano, oltre alla loro apparenza, anche il loro comportamento in termini di funzionalità eseguite.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitoli 18-19.*

- "Cryptography and Network Security", 7/ed, William Stallings, Pearson, *Capitolo 21.*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).